AgentGuard 智盾实验分析报告

实验一：确定性校园靶场前后版本对照（生产复验）

- 数据类型：确定性校园 Agent 的真实执行结果。
- 运行环境：Vercel FastAPI 生产部署 + Neon PostgreSQL。
- 测试集：`desktop-security-v1`，26 条，套件版本 1.1。
- 运行方式：通过生产 `/api/v2/runs` 创建任务，再读取持久化逐用例结果。
- 数据来源：`deterministic-production-campus-agent`。

版本	通过	失败	待复核	通过率	生产 Run ID
V1.0 缺陷版	7	19	0	26.9%	`225dc1e7-8e45-40af-9aec-dfa824cdf6f1`
V2.0 修复版	26	0	0	100.0%	`88e67ed6-972e-4656-b4e7-c17b46a3085f`

结论：修复后同一测试集通过数从 7/26 提升到 26/26，共保存 52 条逐用例结果。所有判定来源均为固定规则，未使用真实大模型。

实验一（续）：独立审核真值与风险指标

- 真值定义：`agent-vulnerability-v1`。
- 真值文件：`ground_truth_seeded_26.csv`。

- 规则：只有运行 `agent_id` 命中 `reviewed_agent_ids` 且版本匹配时才选择 `v1_risk_present` / `v2_risk_present`；`risk_tag` 只代表攻击意图，不参与真值推断。
- 未审核真值不进入 Precision / Recall / F1。

项目	数值
已审核运行	52
未审核运行	0
TP	19
FP	0
FN	0
TN	33
Precision	100.0%
Recall	100.0%
F1	100.0%

上述指标由 `scripts/recompute_ground_truth_metrics.py` 从生产逐用例结果和独立真值文件复算。它证明确定性校园靶场 V1.0 缺陷与 V2.0 修复的回归效果，不代表真实 LLM/Dify 的安全准确率。

实验二：AI 生成用例与混合判定

- 代码路径已实现：`llm_provider.py`、`/api/v2/test-suites/generate`。
- 真实模型调用状态：`BLOCKED`。
- 原因：缺少模型地址、模型名和服务端 API Key。
- 当前只能证明规则模板与人工审核契约可运行，不能证明真实模型生成效果。

实验三：攻击链证据定位

- 生产复验生成 19 条 Finding，节点包含 input、behavior、impact 和 fix。

- 每个节点保存 `run_id`、`case_id`、`trace_event_ids`、basis、confidence 和人工复核状态。
- 前端已实际展示缺陷列表和 Evidence Flow。
- 真实 Dify 风险实验：`NOT_RUN`；不得把本地确定性靶场结果当作 Dify 结果。

实验四：真实 Dify 修复回归

- 环境依赖：授权 Dify 地址、API Key、知识库和工作流导出。
- 当前状态：`BLOCKED`。
- 不得用确定性靶场结果代替真实 Dify 结果。

实验五：PostgreSQL 跨部署持久化

- 生产数据库：Neon PostgreSQL，Alembic 当前版本 `0002_case_ground_truth (head)`。
- 两个 Run ID 在创建后经历两次生产重新部署，仍通过 `/api/v2/runs/{id}` 返回 200。
- 证据文件：`04_运行证据/neon_cross_deployment_persistence.json`、`neon_alembic.json`。
- 结论：`PASS`。这证明线上记录不是 Vercel `/tmp` SQLite 的临时数据。